

PROJE RAPORU: Hibrit Yaklaşımlı SQL Enjeksiyon (H-SQLi)

Tespit Sistemi

Projeye Genel Bakış

Günümüzde web uygulamalarının veritabanlarına yönelik en büyük siber tehditlerden biri SQL Enjeksiyonu (SQLi) saldırılarıdır. Siber güvenlik savunmasında geleneksel imza tabanlı (signature-based) Saldırı Tespit Sistemleri (IDS), bilinen tehditleri yakalamada çok hızlı olmalarına rağmen yeni nesil veya şekil değiştirmiş saldırıları kaçırabilmektedir. Makine öğrenmesi (anomali tabanlı) sistemler ise yeni saldırıları tespit etmede başarılı olsalar da tek başlarına kullanıldıklarında yavaş çalışabilir veya yanlış alarmlar üretebilirler. Bu proje, makalede de önerildiği gibi, imza tabanlı sistemlerin hızı ile makine öğrenmesi sistemlerinin zekasını birleştirerek "Hibrit Yaklaşımlı SQL Enjeksiyon Tespit Sistemi (H-SQLi)" geliştirmeyi amaçlamaktadır.

Uygulama Adımları

Proje, modüler bir mimariyle Python dili kullanılarak dört temel aşamada hayata geçirilmiştir:

- **Veri Hazırlığı ve Model Eğitimi (train.py):** 30.921 satırdan oluşan ve "Temiz (0)" ile "Saldırı (1)" etiketlerini barındıran SQL veri seti kullanılmıştır. Veriler TfidfVectorizer ile makine öğrenmesinin anlayabileceği sayısal vektörlere dönüştürülmüştür. Sistem zekası olarak Karar Ağacı (DecisionTreeClassifier) algoritması seçilmiş, verinin %70'i eğitim %30'u test için ayrılarak model eğitilmiş ve joblib ile diske (model.pkl) kaydedilmiştir.
- **Katman 1 - İmza Motorunun Kurulması (detector.py):** Sistemin birinci güvenlik kapısı olarak Python re (Regex) kütüphanesi ile bilinen saldırı kalıpları (Totoloji, UNION SELECT, Yorum Satırı istismarı vb.) tanımlanmıştır. Gelen sorgu bu kalıplardan biriyle eşleşirse anında "BLOCKED_BY_SIGNATURE" olarak engellenmektedir.
- **Katman 2 - ML Motorunun Entegrasyonu (detector.py):** İmza filtresinden "temiz" olarak geçmeyi başaran sorgular, diske kaydedilen Karar Ağacı modeline aktararak anlamsal bir anomali içerip içermediği test edilir. Eğer yapay zeka anormal bir durum sezerse "BLOCKED_BY_ML" kararı verir.
- **Kullanıcı Arayüzünün Tasarlanması (main.py):** Geliştirilen bu hibrit mimariyi interaktif bir şekilde test edebilmek için colorama kütüphanesi ile renkli bir komut satırı arayüzü (CLI) tasarlanmıştır.

Sonuç

Eğitilen makine öğrenmesi modeli %99.17 Doğruluk (Accuracy), %99.18 Kesinlik (Precision) ve %98.87 F1-Skoru gibi son derece yüksek akademik başarı oranlarına ulaşmıştır. Sistem üzerinde yapılan canlı testlerde şu üç temel senaryo başarıyla kanıtlanmıştır:

- Normal bir kullanıcı girdisi (örneğin masum bir kelime) her iki katmandan da geçerek "SAFE (Güvenli)" olarak işaretlenmiştir.

- Klasik bir saldırgan girdisi olan admin' OR 1=1 -- şeklindeki bilinen bir totoloji saldırısı, yapay zekayı hiç yormadan anında Katman 1 (İmza Motoru) tarafından yakalanmıştır.
- Sistemin sınırlarını zorlayan, imza motorundaki kuralları atlatmak üzere tasarlanmış admin' OR 5 > 2 veya 1' AND (SELECT count(*) FROM users) > 0 gibi zeki ve mantıksal saldırı denemeleri kural tabanlı motoru (Katman 1) aşmasına rağmen, anlamsal anormallikleri fark eden Katman 2 (Makine Öğrenmesi) tarafından başarıyla tespit edilerek engellenmiştir.

Özetle bu proje, sadece imza kullanan sistemlerin körlüğünü ve sadece makine öğrenmesi kullanan sistemlerin yavaşlığını ortadan kaldırarak; web uygulamaları için son derece hızlı, güvenilir ve yenilikçi bir siber güvenlik savunma mekanizması (Kavram Kanıtı - PoC) ortaya koymuştur.